

TECHNICAL DOCUMENTATION

Airtel Secure Readiness Check

Complete reference for the 12-question CyberSecurity readiness assessment: logic, scoring engine, architecture builder, advisory engine, PDF generation, component reference, and industry weighting rationale.

PRODUCT	VERSION	BRANCH	GENERATED
Readiness Check	1.0	main	04 June 2026

Airtel Secure Readiness Check — Complete Documentation

A 4-minute, 12-question CyberSecurity readiness assessment for Indian enterprises. Generates a 0–100 maturity score, domain-level breakdown, threat exposure profile, regulatory mapping, a recommended Airtel Secure stack, a tier-aware security architecture blueprint, and an 11-page consultant-style PDF report.

Production URL: <https://airtelforbusiness.com/security-readiness-check> **Repository:** [sidd8rth/Maturity-Assessment](#) **Branch:** [main](#) (compliance-maturity merged via PR #3 and #4)

1. Overview & Value Proposition

What the tool does

The Readiness Check asks 12 multiple-choice questions across 7 security domains, weights answers by industry, and produces:

- **An overall score (0–100)** mapped to one of four tiers: Basic / Developing / Established / Advanced
- **A domain-level breakdown** showing which of the 7 domains drag the score down
- **A tier-aware threat list** showing the attacks most likely to hit a customer of this maturity
- **A regulatory list** showing which Indian frameworks (DPDP, RBI, SEBI, IRDAI, CERT-In) apply
- **A 3-item Airtel Secure stack recommendation** mapped from weakest weighted domains
- **A security architecture blueprint** (Starter / Standard / Advanced tiers) showing modules organised by Network Security / Secure Workforce / Secure Workload / Managed Services buckets, tagged CORE / REQ / REC
- **An advisory engagement list** (VAPT, Gap & Risk Assessment, Red Team, Complex Implementations, IR Planning, Forensics & RCA) selected by industry, maturity and size
- **A tier-aware narrative summary** explaining the why behind each module and what changes at the next tier
- **An 11-page consultant-style PDF report** as a downloadable deliverable

Why it exists

Indian enterprise CISOs and IT heads typically have to choose between a free, generic self-assessment (Gartner template, Reddit checklists) or a paid 6-week consulting engagement. This tool sits in between: 4 minutes of effort, output quality close to a consultant-grade audit, no field collection, no contact wall — and the score directly motivates a "Talk to an Expert" conversation with Airtel Secure.

Who it is for

- **Primary:** CISOs, IT heads and Heads of Security at Indian mid-to-large enterprises (500 to 10,000+ users) in BFSI, Healthcare, Manufacturing, IT/ITES, Retail and Government.

- **Secondary:** Business owners and CEOs who want a non-technical readout of their security posture before scheduling internal reviews.

Tech stack

- React 19 + TypeScript 5
- Vite 6 for build/dev
- Tailwind CSS for styling
- framer-motion for screen transitions and micro-interactions
- @react-pdf/renderer for the downloadable PDF (lazy-loaded)
- No backend. Entirely client-side, runs in the browser. No data leaves the device until the user clicks "Talk to an Expert".

2. End-to-End User Flow



Stage list (managed in App.tsx via Stage union)

Stage	Screen	What user does	Next
intro	IntroScreen	Reads value-prop, clicks "Start readiness check"	industry
industry	IndustryScreen	Picks one of 6 verticals (BFSI / Healthcare / Govt PSU / Manufacturing / IT-ITES / Retail)	environment

Stage	Screen	What user does	Next
environment	EnvironmentScreen	Picks On-prem / Hybrid / Cloud-first	orgsize
orgsize	OrgSizeScreen	Picks one of 4 size bands (<500 / 500-2K / 2K-10K / 10K+)	quiz
quiz	QuizScreen	Answers 12 questions, auto-advances 700ms after selection	results
results	ResultsScreen	Reviews score, threats, blueprint; toggles tabs; downloads PDF	(retake reloads page)

Retake behaviour

`handleRetake` in `App.tsx` is a hard `window.location.reload()`. This was a deliberate decision: soft state-reset had flaky interactions between `AnimatePresence mode="wait"`, motion exit animations, and conditional rendering that left the page blank under some race conditions. Hard reload guarantees a clean start every time; both Retake entry points (Header button + bottom link inside `ResultsScreen`) wire to the same handler.

The Retake button is only rendered in the Header when `stage === 'results'` (the prop is gated in `App.tsx`).

Stage transitions

- Driven by `<AnimatePresence mode="wait" initial={false}>` around the screens in `App.tsx`.
- Each screen wraps its content in `<motion.div>` with `initial` / `animate` / `exit` props.
- Transition duration: 200ms with easing `[0.2, 0.8, 0.2, 1]` (fast cubic).
- Vertical offset is small (`y: 8 → 0 → -4`) so the transition feels like a snap, not a slide.
- `layout` props were removed from step screens because they conflicted with `mode="wait"` and added redundant computation for full-page swaps.

3. Information Architecture

App shell (rendered on every page)

- **Header** — sticky top bar. Logo + "Readiness Check" subtitle + (conditionally) Retake button + Talk to an Expert button.
- **Breadcrumb** — `Home / Security / Readiness Check`. Home and Security links open `airtel.in/b2b` and `airtel.in/b2b/network-security` in new tabs.
- **Footer** — Logo + Terms, Privacy, Cookie Notice, Contact Us links. All external in new tabs.

Main content area

`<main>` has responsive padding (`px-4 sm:px-6 lg:px-10 py-8 sm:py-10`) and a transitioning `max-width`: - **Results stage**: `max-w-[1600px]` to accommodate the wide 2-column layout. - **Every other stage**: `max-w-quiz` (1000px) for focused linear flow.

The width change is CSS-transitioned (`transition-[max-width] duration-300`).

Results page layout

Two tabs at the top of `ResultsScreen`:

Tab 1 — Maturity score

2-column grid (`grid-cols-1 lg:grid-cols-[360px_1fr]`):

- **Left column (sticky on `lg`)**: 1. Score card — `ScoreRing` (animated SVG) + tier pill + tier message + inline CTA 2. Threats card — `ThreatList` with up to 4 tier-specific threats
- **Right column**: 1. Domain breakdown — `DomainBars` showing 7 horizontal bars (one per domain) 2. Blueprint — `RecommendationList` showing top 3 Airtel Secure stack picks 3. Regulations card — pill list of frameworks (DPDP / RBI / etc.)

Tab 2 — Architecture blueprint

- Title row + counts ("X modules · Y advisory engagements · Z regulations covered")
- `TierToggle` (Starter / Standard / Advanced) — default tier is score-aware (see §9)
- `Diagram` — bucketed module chips with status badges (CORE / REQ), regulation dots, advisory wraparound
- `NarrativeSummary` — generated paragraph + per-module reasoning + growth path

Modals

- `TalkToExpertModal` — currently defined but not wired (CTAs all open external Airtel contact page in new tab to never lose assessment state)
- **Download prompt** — auto-opens on `ResultsScreen` mount, has `<50` and `>=80` callouts, two action buttons

4. Domain Model & Types

`src/types.ts`

```
type IndustryId = 'bfsi' | 'manufacturing_ot' | 'healthcare' | 'it_ites' | 'retail_ecomm' | 'govt_psu'

type Environment = 'on_prem' | 'hybrid' | 'multi_cloud'

type OrgSize = 'small' | 'mid' | 'large' | 'xlarge'

type Domain = 'Identity & Access' | 'Network Security' | 'Detection & Response'
              | 'Governance & Compliance' | 'Workforce Security' | 'Workload Security' | 'AI Technology'

type Tier = 'Basic' | 'Developing' | 'Established' | 'Advanced'

type ResultsView = 'business' | 'technical' // legacy; fixed to 'technical' in current build
```

A **Question** has a **domain**, a question string, optional **terms** (glossary tooltips), and 4 **opts** each with a score **s**: 1|2|3|4, a short **sub** and a **plainSub** plain-English alternative.

A **DomainScore** is `{ name: Domain, pct: number }` — **pct** is normalised 0–100.

src/architecture/lib/types.ts (separate engine)

```
type Concern = 'ransomware' | 'data_exfiltration' | 'ddos' | 'compliance_pressure'
| 'insider_threat' | 'cloud_misconfig' | 'phishing_email'
| 'ot_iot_exposure' | 'third_party_risk'
type Maturity = 'nascent' | 'developing' | 'mature'
type Tier = 'starter' | 'standard' | 'advanced' // note: different from maturity Tier
type CapabilityStatus = 'foundational' | 'mandated' | 'recommended' | 'future_state' |
'excluded'
```

A **Capability** is a security module (Firewall, NDR, EDR, etc.) loaded from **capabilities.json**. It has **bucket**, **layer**, **concerns_addressed[]**, **environments[]**, **min_size**, **critical_for_industries[]**, **regulations[]**, **is_foundational**, **description**.

A **ScoredCapability** adds **score**, **status**, **reasons[]**, optional **futureUnlockReason**, **matchedRegulations[]**.

UserInputs for the architecture engine is `{ environment, size, industry, concerns[], maturity? }`. We derive **concerns[]** and **maturity** from the maturity engine via **src/lib/bridge.ts** (see §9), so the user only fills the maturity quiz, not two questionnaires.

5. Maturity Scoring Engine

File: **src/lib/scoring.ts**

Algorithm

```
For each answered question:
  domain[q.domain].total += opt.s (1, 2, 3, or 4)
  domain[q.domain].count += 1

For each domain:
  raw_avg = total / count (range 1..4)
  pct = round((raw_avg - 1) / 3 * 100) (normalises to 0..100)

For overall:
  overall = round(Σ domain_pct * weight[industry][domain])
```

Weights (src/data/weights.ts)

Each industry has a 7-domain weight vector summing to 1.0. Examples:

Domain	BFSI	Manufacturing	Healthcare	IT/ITES
Governance & Compliance	0.25	0.15	0.20	0.10
Identity & Access	0.20	0.10	0.15	0.20
Network Security	0.10	0.25	0.10	0.10
Detection & Response	0.15	0.20	0.15	0.15
Workforce Security	0.05	0.15	0.10	0.10
Workload Security	0.20	0.10	0.25	0.25
AI Technology	0.05	0.05	0.05	0.10

The rationale: BFSI cares most about Governance and Identity (regulatory pressure + insider risk). Manufacturing weighs Network and Detection (OT exposure + lateral movement risk). Healthcare prioritises Workload (PHI data systems). IT/ITES prioritises Workload + Identity (SaaS-heavy estate).

Tier mapping

Score range	Tier
0 – 34	Basic
35 – 59	Developing
60 – 79	Established
80 – 100	Advanced

Edge cases handled

- Unanswered questions are skipped (no penalty)
- Missing weight vector falls back to `WEIGHTS.it_ites`
- Domains with no answers don't appear in the breakdown
- All percentages are integer-rounded for display

6. Recommendation Engine (Airtel Stacks)

File: `src/lib/recommendations.ts` **Output:** `StackKey[]` (top 3)

Algorithm

For Advanced tier: return a hand-picked, industry-specific list from `ADVANCED_PICKS[industry]`. These are higher-value stacks like Red Team Retainer, Supply Chain Risk, AI Security, CISO Advisory etc. that are wasted on Basic tier customers.

For Basic / Developing / Established tiers: 1. Compute `weightedPct = pct * weights[industry][domain]` for every domain. 2. Sort ascending → weakest weighted domains first. 3. For each weak domain, map to its `primary` stack via `DOMAIN_STACK`. Skip duplicates. 4. **PS override:** if `overall < 45`, force "Professional Services" into the top 3 (because customers this exposed need a structured foundation engagement before tools). 5. Fill any remaining slots with secondary stacks. 6. Return top 3.

DOMAIN_STACK mapping (`src/data/stacks.ts`)

Weak domain	Primary stack	Secondary stack
Identity & Access	Secure Workforce	Managed Services
Workforce Security	Secure Workforce	Managed Services
Network Security	Network Security	Managed Services
Detection & Response	Managed Services	Secure Workforce
Governance & Compliance	Professional Services	Managed Services
Workload Security	Secure Workload	Managed Services
AI Technology	Secure Workload	Managed Services

Stack copy (`STACK_COPY`)

Each stack has { `title`, `desc`, `href?` }. The 5 mainstream stacks have hrefs pointing to live Airtel B2B pages; the 6 advanced stacks are descriptive-only (no public landing pages):

- **With href** (linked tiles): Secure Workforce, Network Security, Secure Workload, Managed Services, Professional Services
- **No href** (descriptive only): Red Team Retainer, Supply Chain Risk, AI Security, Cyber Resilience, Threat Intelligence, CISO Advisory

7. Architecture Builder Engine

File: `src/architecture/lib/scoring.ts` **Data:** `src/architecture/data/capabilities.json` (~30 capabilities)

Per-capability scoring

```
score = 0

if matched_concerns >= 1:
    score += 3 * matched_concerns
    if env_match:
        score += 2
```



```
if industry_critical:
    score += 2
if regulation_match:
    score += 3
```

Reason strings accumulate alongside the score so the UI can show "Why recommended" tooltips.

Status assignment

```
if env not matched:
    status = excluded (capability not shown)

else if size not met:
    if score >= 5:
        status = future_state (shown dashed, "unlocks at next size")
    else:
        status = excluded

else: (env + size OK)
    if is_foundational AND industry_critical:
        status = foundational (CORE badge, red)
    elif matched_regulations.length > 0:
        status = mandated (REQ badge, navy)
    elif score >= 5:
        status = recommended (REC badge, white)
    else:
        status = excluded
```

professional_services and **incident_response** bucket items are NOT scored here — they are handled by the Advisory engine (§8) and never appear in the diagram itself.

Tier construction (**buildTiers**)

Tier	Contents
Starter	Only foundational items (the absolute baseline an industry can't skip)
Standard	foundational + mandated + recommended, capped by size (small: 6, mid: 10, large: 15, xlarge: ∞)
Advanced	Standard + remaining recommended (no cap)

Foundational items always appear first in every tier — the size cap can never drop them.

Within each group, items are sorted by **score** desc.

`futureState[]` is computed separately and shown only when `tier === 'advanced'` is selected (rendered as dashed chips).

Default tier on landing

Driven by maturity tier:

```
Basic, Developing → starter (need basics first)
Established → standard
Advanced → advanced
```

Logic in `ResultsScreen.tsx` (`defaultArchTier`).

8. Advisory Engagement Engine

File: `src/architecture/lib/advisory.ts` **Output:** `AdvisoryItem[]`

These are professional-services engagements that wrap around the diagram (not slotted into a bucket). Each has hard-coded inclusion rules:

Engagement	Condition
Gap & Risk Assessment	<code>maturity ∈ {nascent, developing}</code>
VAPT	<code>industry ∈ {BFSI, IT/ITES, Retail, Govt, Healthcare, Manufacturing}</code> OR <code>concerns</code> includes <code>data_exfiltration</code> , <code>compliance_pressure</code> , or <code>ot_iot_exposure</code>
Red Team-Blue Team	<code>maturity === 'mature'</code> AND <code>size ∈ {large, xlarge}</code> AND <code>industry ∈ {BFSI, Govt, IT/ITES}</code>
Complex Implementations	Standard tier has ≥ 5 modules
Incident Response Planning	<code>industry ∈ {BFSI, Healthcare, Govt}</code> OR industry regs include RBI / IRDAI / CERT-In
Forensics & RCA	<code>size ∈ {mid, large, xlarge}</code> AND <code>industry ∈ {BFSI, Healthcare, Govt}</code>

Items deduplicate on `id` after assembly.

Maturity is computed via `inferMaturity` when not passed: xlarge BFSI/Govt/IT default to mature; xlarge others to developing; large/mid to developing; small to nascent.

9. Bridge Logic (Maturity → Architecture)

File: `src/lib/bridge.ts`

The architecture engine normally needs two extra inputs from the user: which attacks they fear (`concerns[]`) and a self-rated maturity (`Maturity`). The Readiness Check derives both from the maturity score so the user

only fills one questionnaire.

`tierToConcerns(tier) → Concern[]`

Maturity tier	Inferred concerns
Basic	phishing_email, ransomware, ddos, data_exfiltration
Developing	ransomware, cloud_misconfig, insider_threat, phishing_email
Established	cloud_misconfig, insider_threat, third_party_risk
Advanced	third_party_risk, cloud_misconfig, ot_iot_exposure

Rationale: lower-maturity customers face broad, low-friction attacks; top-decile customers face supply-chain and OT-IoT level threats.

`tierToArchitectureMaturity(tier) → Maturity`

```
Basic → nascent
Developing → developing
Established → mature
Advanced → mature
```

10. Narrative Generation

File: `src/architecture/lib/narrative.ts` **Output:** `{ intro, moduleReasons[], regulationsCovered[], growthPath }`

Builds the prose displayed in **NarrativeSummary** on the architecture tab and in the PDF report.

- `intro` — natural-language paragraph: "For a [size] [industry] organisation in a [env] environment, with top concerns around [A, B and C], we've put together X core modules and Y advisory engagements at the [tier] tier." Handles "a/an" article correctly; joins concerns with Oxford comma logic.
- `moduleReasons[]` — one bullet per active module explaining which concerns/environment/industry/regulations make it relevant.
- `regulationsCovered[]` — list of regulations the active stack addresses.
- `growthPath` — "What changes at the next tier" prose pulled from `future_state` items.

All copy is template-driven with no random / non-deterministic generation; the same inputs always produce the same output.

11. PDF Report Generation

File: `src/Lib/ReportPDF.tsx` **Library:** `@react-pdf/renderer` (lazy-loaded — only fetched when user clicks Download)

The report is an 11-page consultant-style deliverable styled in a red + grey palette.

Page-by-page structure

Page	Layout	Content
1	Cover (full-bleed dark)	Confidential · Prepared for [industry] · Title · Lead · Score / Tier / Industry / Generated metadata strip
2	Body	Contents — 4 numbered sections with descriptions and page numbers
3	Section divider	Big "01" / "Section one" / "Executive summary" / lede
4	Body	Executive summary — Hero score block + 3-stat strip (threats, regulations, lowest domain) + Top 3 priorities
5	Section divider	"02" / "Risk profile"
6	Body	Risk profile — 2-col: Threats list + Domain bars; Regulations row; pull quote calling out weakest domain
7	Section divider	"03" / "Recommended architecture"
8	Body	Architecture — Inline 4-item legend (CORE / REQ / REC / Future-state) + modules grouped by bucket + advisory pills
9	Section divider	"04" / "The 90-day plan"
10	Body	90-day plan — 3 tier-aware phases (Days 1-30 / 31-60 / 61-90) with title + body each
11	Closing (full-bleed dark)	What is next · CTA title (tier-aware) · CTA body · "Talk to an Airtel Secure expert →" Link button · Score / Tier / Industry metadata

Styling system

- **Palette:** RED `#c81010` (primary accent), INK `#1a1f2a` (text), 7-step grey scale `#374150` → `#f6f7f9`
- **Type:** Helvetica family throughout (built-in to react-pdf, no font fetching). H1 30pt, lede 11pt, body 10pt, captions 8.5pt
- **Margins:** 52pt horizontal, 72pt top, 64pt bottom
- **Page footer (fixed):** copyright + page number ("X of Y")
- **Running header (fixed):** brand + "Airtel Secure · Readiness Check" + section label, with rule line below

Score-aware content

The 90-day plan adapts to tier: - Basic/Developing → "Close the front door", "See what is happening", "Reduce attack surface" - Established → "Compress response time", "Extend zero-trust", "Validate continuously" - Advanced → "Stress-test resilience", "Lock down supply chain", "Operationalise AI security"

Tier pill, CTA title and CTA body all come from **TIER_MESSAGES** and **TIER_CTA** in `src/data/tierMessages.ts`.

Closing CTA button

A real clickable `<Link>` (react-pdf) with red background and white text — points to the UTM-tagged Airtel contact URL.

Lazy loading

ResultsScreen does:

```
const [{ pdf }, { ReportPDF }] = await Promise.all([
  import('@react-pdf/renderer'),
  import('../lib/ReportPDF'),
])
```

...so the 1.46 MB react-pdf chunk is NOT in the main bundle. Users who don't click Download never download it.

12. Screen-by-Screen Reference

IntroScreen (`src/screens/IntroScreen.tsx`)

- Eyebrow pill: "12 questions · ~4 minutes"
- H1: **"Assess your enterprise CyberSecurity Readiness"**
- Subtitle: "12 questions across 7 domains. Get your score, domain breakdown, and a personalised Airtel Secure blueprint."
- CTA: "Start readiness check →" (navy button, right-aligned)

IndustryScreen

- 6 industry tiles in a 2-col mobile / 3-col desktop grid
- Auto-advances after selection (no Next button)
- Industries come from **INDUSTRIES** in `src/data/industries.ts`

EnvironmentScreen

- 3 environment tiles (On-premises / Hybrid / Cloud-first) with emoji icons
- 1-col mobile / 3-col desktop

OrgSizeScreen

- 4 size bands (<500 / 500-2K / 2K-10K / 10K+)
- 2-col mobile / 4-col desktop

QuizScreen (the work horse)

- Renders one **Question** at a time from **QUESTIONS** array
- Progress bar at top showing "Question X of 12" and approximate minutes left
- 4 options as **OptionTile** cards in a 1-col mobile / 2-col desktop grid
- Glossary **TermChip** buttons inline under the question, expand to tooltip panels
- Auto-advances 700ms after selecting an option (**AUTO_ADVANCE_MS**)
- Back / Next buttons for non-auto navigation
- Last question's "Next" becomes "See results"

ResultsScreen (largest screen)

- Hero block with H1 "Your security posture report", meta line, 4 context pills (industry, env, size, tier), Download report button
- Tab selector (Maturity / Architecture) with animated red pill (**layoutId="result-tab-pill"**)
- **Maturity tab**: left col (Score card + Threats), right col (Domain breakdown + Blueprint + Regulations)
- **Architecture tab**: title + counts row + TierToggle, Diagram in a SectionCard, NarrativeSummary below
- Auto-opens download prompt on mount (**useState(true)**)
- Bottom: small Retake link

13. Component Reference

Shell

- **Header** — sticky bar. Logo links to airtel.in/b2b (new tab). Optional Retake button (only when **onRetake** prop is provided, i.e. only on results stage). Talk to an Expert button always visible.
- **Footer** — Logo + Terms / Privacy / Cookie / Contact Us links. All external in new tabs.
- **Breadcrumb** — Home / Security / Readiness Check. Home + Security are links to airtel.in. Left-aligned to content edge.

Display primitives

- **SectionLabel** — small uppercase label with letter-spacing for card headers
- **ScoreRing** — animated SVG ring; takes **score** (0-100) and **size**; animates stroke offset and number
- **DomainBars** — horizontal bar chart with gradient fills per domain (colors from **DOMAIN_COLORS**)
- **ThreatList** — icon + name + description rows in red-outlined cards
- **RecommendationList** — stack tiles with title, desc, optional "Explore →" link (only shown if **href** is set)
- **OptionTile** — quiz option card with **t**, **sub**, and **plainSub** paragraphs; selected state has red ring + light-red fill

- **TermChip** — pill button that toggles a dark tooltip panel above it. Wraps glossary terms in question text.
- **ViewToggle** — segmented control (legacy, fixed to 'technical' in current build but kept available)
- **PlainToggle** — minimal slider toggle used in OptionTile to switch between **sub** and **plainSub**

Architecture builder

- **Diagram** — the headline visual. Renders advisory wraparound at top (dashed amber), then 4 buckets as rows (Network Security / Secure Workforce / Secure Workload / Managed Services), each with module chips. Each chip is colored by status with a CORE/REQ badge on the top-right corner. Tooltip on hover shows description + "Why recommended" reasons + matched regulations.
- **TierToggle** — 3 segmented buttons (Starter / Standard / Advanced) with module counts. Full-width on mobile.
- **ComplianceOverlayToggle** — currently disabled (compliance dots always show). Kept in codebase but not rendered.
- **NarrativeSummary** — card with intro paragraph, "Why these modules" list, "Regulations covered" pills, "Where next" growth path.
- **Icon** — wrapper around the icon set used in **Diagram** (building / shuffle / cloud).

Modals

- **TalkToExpertModal** — present in codebase, NOT wired up. CTAs all open external contact URL in new tab instead (deliberate decision: never lose assessment state, give every user a deep link, leverage UTM tracking on the Airtel domain).

14. Data Files Reference

`src/data/questions.ts`

12 **Question** objects with domain, question text, glossary terms, and 4 options each. All copy is final / production-ready.

`src/data/weights.ts`

Industry × Domain weight matrix (see §5).

`src/data/industries.ts`

6 **Industry** objects with id, label, sub, icon.

`src/data/threats.ts`

Tier-keyed **TIER_THREATS**: `Record<Tier, ThreatInfo[]>` (4 threats per tier). Each threat has icon + name + desc.

`src/data/tierMessages.ts`

- **TIER_MESSAGES[tier][view]** — tier message shown on score card (view fixed to 'technical')
- **TIER_CTA[tier]** — { title, body, primary } used in score-card CTA and PDF closing page

src/data/stacks.ts

- `StackKey` union of 11 stack names
- `STACK_COPY[key]` — { title, desc, href? }
- `DOMAIN_STACK[domain]` — { primary, secondary } mapping
- `ADVANCED_PICKS[industry]` — hand-picked top 3 for Advanced tier

src/architecture/data/capabilities.json

~30 capabilities, each with full schema (id, name, bucket, layer, concerns_addressed, environments, min_size, critical_for_industries, regulations, is_foundational, description). Recent rename:

NDR/NAC/DLP/VDI/DAM/AppSec/Anti-DDoS/AI SOC are expanded to full forms; VAPT, DSPM, CNAPP, Workload IAM kept as-is.

src/architecture/data/regulations.json

Industry-keyed list of applicable regulations (`bfsi` → [RBI, SEBI, DPDP, CERT-In] etc.).

src/architecture/data/concerns.json

Concerns catalog (id + display label).

src/architecture/data/industries.json

Same 6 industries with the architecture engine's internal labels.

15. Analytics, UTM & External Links

All "Talk to an Expert" / contact CTAs use a single UTM-tagged URL:

```
https://www.airtel.in/b2b/contact-us?utm_source=referral&utm_medium=bamboobox&utm_campaign=airtel+secure&utm_id=security+assessment
```

Locations: - Header right button - Footer "Contact Us" - ResultsScreen score-card CTA - Download popup secondary button - ReportPDF closing page Link button

Every external link uses `target="_blank" rel="noopener noreferrer"`

This is the most important UX invariant: clicking any Airtel link must NEVER navigate the user away from the Readiness Check, because the in-page state (their answers + score) is not persisted server-side. Lose the tab, lose the assessment.

Stack tile links (`RecommendationList`)

Link directly to the corresponding `airtel.in/b2b/{stack-name}` page (e.g. `/secure-workforce`, `/managed-services`). No UTM on these — they're internal funnel navigation rather than lead capture.

Canonical and OG (`index.html`)

- `<link rel="canonical">` → `airtelforbusiness.com/security-readiness-check`

- OG title / description / URL for LinkedIn / WhatsApp / Twitter card previews
- Twitter card: `summary_large_image`

16. Build, Bundle & Deployment

Local development

```
npm install
npm run dev # Vite dev server on port 5173
npm run build # produces dist/
npm run preview # serve dist/ locally
```

Production bundle (after `npm run build`)

Asset	Size	Gzip	Loaded
<code>index.html</code>	0.84 kB	0.46 kB	Always
<code>index-*.css</code>	28.96 kB	6.03 kB	Initial
<code>index-*.js</code> (main app)	367.68 kB	116.92 kB	Initial
<code>ReportPDF-*.js</code>	24.62 kB	6.90 kB	Lazy (Download click)
<code>react-pdf.browser-*.js</code>	1,461.13 kB	491.12 kB	Lazy (Download click)

Vite warns about the react-pdf chunk being >500 kB — this is informational. The main bundle (116 kB gzip) is what matters for first paint; react-pdf only loads when the user actually clicks Download PDF.

Deployment target

Static hosting at airtelforbusiness.com/security-readiness-check. No server runtime required (the app is 100% client-side). Could go on: - Vercel / Netlify (zero config) - S3 + CloudFront - Nginx static - Or wedged into an existing Airtel WordPress/CMS as a static asset folder

CI / Build steps that should run before deploy

1. `npm ci`
2. `npm run build`
3. Optional: `npx tsc --noEmit` for type check (currently runs clean)
4. Upload `dist/` contents to hosting path

17. Mobile, A11y & Browser Support

Mobile responsive checklist

- All screens are mobile-first with `sm:` / `md:` / `lg:` breakpoints
- `Header` collapses subtitle on `<md`, keeps Retake + Talk to Expert text on every breakpoint
- All grids switch from 2-col / 3-col / 4-col on desktop to 1-col or 2-col on mobile
- Download modal becomes a bottom sheet (`rounded-t-2xl, items-end`) on `<sm`
- `Diagram` modules use `flex-wrap` so chips reflow naturally on narrow screens
- `TierToggle` becomes full-width with `flex-1` buttons on mobile

Tailwind breakpoints (`tailwind.config.js`)

Token	Width
<code>xs</code>	480 px
<code>sm</code>	640 px
<code>md</code>	768 px
<code>lg</code>	1024 px
<code>xl</code>	1280 px
<code>2xl</code>	1536 px

Accessibility

- All interactive elements have semantic HTML (`<button>` not `<div onClick>`)
- Icons use `aria-hidden` so screen readers skip them
- Modals have `role="dialog"`, `aria-modal="true"`, `aria-labelledby`
- ESC key closes the Talk-to-Expert modal (in `useEffect` listener)
- Focus is moved to the first form field when the modal opens
- `aria-label` on icon-only buttons (e.g. Retake)
- Tab pill animation uses `layoutId` for smooth keyboard-focus tracking

Browser support

Chrome / Edge / Safari / Firefox last 2 versions. No IE11 support. Mobile Safari and Chrome on Android verified.

Performance

- Initial bundle: 116 kB gzip → ~200 ms TTI on a fast 4G connection
- No analytics or third-party scripts on the page
- Font is the Airtel Sans webfont (already cached for users who've visited any airtel.in property)

18. Glossary

Term	Meaning
Domain	One of 7 security pillars: Identity & Access, Network Security, Detection & Response, Governance & Compliance, Workforce Security, Workload Security, AI Technology
Tier (maturity)	Score-based bucket: Basic (0-34), Developing (35-59), Established (60-79), Advanced (80-100)
Tier (architecture)	Coverage band: Starter (foundational only), Standard (foundational + mandated + recommended capped), Advanced (everything)
Foundational / CORE	Capability marked <code>is_foundational=true</code> that is critical for the user's industry. Cannot be dropped from the stack regardless of score.
Mandated / REQ	Capability whose <code>regulations</code> list intersects with the industry's applicable frameworks. Required by law.
Recommended / REC	Capability that scored ≥ 5 based on concerns + env + industry, but is not foundational or mandated.
Future-state	Capability that fits the user's environment + concerns but the user's current size doesn't yet warrant it. Shown dashed; reason explains what size triggers it.
Excluded	Capability that did not pass env / size / score gates. Never shown.
Maturity (architecture)	Self-rated <code>nascent</code> / <code>developing</code> / <code>mature</code> . Derived from the maturity score via <code>bridge.ts</code> .
Concern	One of 9 attack categories the user is worried about. Derived from maturity tier via <code>tierToConcerns</code> .
Bucket	Visual layer in the architecture diagram: Network Security, Secure Workforce, Secure Workload, Managed Services.
Advisory	Professional-services engagement that wraps around the diagram (VAPT, Gap & Risk Assessment, etc.) rather than slotting into a bucket.

Appendix A — File-by-File Reference

```
src/
  ■■■ App.tsx Stage state machine + AnimatePresence routing
  ■■■ main.tsx React 19 root entry
  ■■■ types.ts Maturity-engine types
  ■
  ■■■ data/
  ■ ■■■ questions.ts 12 quiz questions
```

- ■■■ weights.ts Industry × Domain weight matrix
- ■■■ industries.ts 6 industries with metadata
- ■■■ threats.ts Tier → threats[] mapping
- ■■■ tierMessages.ts Tier messages + CTA copy
- ■■■ stacks.ts StackKey enum + copy + domain mapping
-
- ■■■ lib/
- ■■■ scoring.ts Maturity scoring engine
- ■■■ recommendations.ts Top-3 stack picker
- ■■■ bridge.ts Maturity → Architecture concerns/maturity bridge
- ■■■ ReportPDF.tsx 11-page PDF report (lazy loaded)
-
- ■■■ components/
- ■■■ Header.tsx / Footer.tsx / Breadcrumb.tsx Shell
- ■■■ AirtelLogo.tsx / AirtelSecureLogo.tsx Brand SVGs
- ■■■ ScoreRing.tsx Animated SVG ring
- ■■■ DomainBars.tsx Horizontal domain bar chart
- ■■■ ThreatList.tsx Threat row cards
- ■■■ RecommendationList.tsx Stack tiles
- ■■■ OptionTile.tsx / PlainToggle.tsx Quiz option components
- ■■■ TermChip.tsx Glossary tooltips
- ■■■ ViewToggle.tsx Business/Technical toggle (legacy)
- ■■■ SectionLabel.tsx Card eyebrow + title
- ■■■ TalkToExpertModal.tsx Lead-capture modal (currently unwired)
-
- ■■■ screens/
- ■■■ IntroScreen.tsx
- ■■■ IndustryScreen.tsx
- ■■■ EnvironmentScreen.tsx
- ■■■ OrgSizeScreen.tsx
- ■■■ QuizScreen.tsx
- ■■■ ResultsScreen.tsx
-
- ■■■ architecture/
- ■■■ lib/
- ■■■ types.ts Architecture-engine types
- ■■■ scoring.ts Per-capability scoring + tier construction
- ■■■ advisory.ts Advisory engagement rules
- ■■■ narrative.ts Tier-aware prose generation

```
■■■ data/
■ ■■■ capabilities.json ~30 capability records
■ ■■■ industries.json
■ ■■■ regulations.json
■ ■■■ concerns.json
■■■ components/
■■■ Diagram/index.tsx Main architecture visual
■■■ TierToggle/index.tsx Starter / Standard / Advanced segments
■■■ ComplianceOverlay/ Compliance overlay toggle (currently always on)
■■■ NarrativeSummary/ Generated prose card
■■■ Icon/index.tsx Local icon set

index.html Title, canonical, OG/Twitter meta
tailwind.config.js Custom palette, breakpoints, maxWidth tokens
vite.config.ts Vite + plugin-react config
package.json Dependencies
```

Appendix B — Notable Design Decisions

- 1. Hard reload on Retake.** Soft state reset had timing races between `AnimatePresence`, motion exit animations, and conditional rendering. A page reload is bulletproof and matches semantic intent ("start over").
- 2. No backend.** Everything runs client-side. The only outbound network call is when the user clicks a Talk-to-Expert link (which opens the Airtel contact page in a new tab). Nothing about the user is stored or sent.
- 3. All external links open in new tab.** Without this, the user could click Talk to Expert at the bottom of the results page, navigate away, and lose the assessment with no way to recover it.
- 4. Two separate "Tier" types** (maturity vs architecture). They mean different things — keep them distinct in types and copy. Maturity Tier is score-driven; Architecture Tier is coverage-driven.
- 5. PDF is lazy-loaded.** `react-pdf` is 1.46 MB. We dynamic-import it only when the user clicks Download — most users won't download, so most users never pay for it.
- 6. Score-aware UI variants.** The download popup adapts (`<50` → low-score callout, `≥80` → advisory callout). The personalised CTA title adapts. The 90-day plan in the PDF adapts. The architecture tier default adapts. All driven by the score, no manual config.
- 7. Foundational labelled as "Core" in the UI** but the internal status key remains `foundational`. This keeps the scoring engine, sorting, and ordering logic untouched while letting marketing copy evolve.
- 8. `mode="wait"` retained in `AnimatePresence`.** Removing it caused layout glitches on step screens. The original bug attributed to `mode="wait"` was actually a multi-condition rendering check on `ResultsScreen` — once that was simplified, `mode="wait"` became safe again.
- 9. No em-dashes in user-facing copy.** Wikipedia's "signs of AI writing" guide lists em-dash overuse as a tell. The humanizer pass replaced them all with periods, commas, or colons.

10. Acronyms expanded selectively. NDR / NAC / DLP / VDI / DAM / AppSec / Anti-DDoS / AI SOC are expanded for clarity. VAPT, DSPM, CNAPP, Workload IAM are kept short because they're industry-standard CISO vocabulary where the abbreviation IS the recognised term.

Appendix C — The 12 Questions in Full

Each question targets exactly one of the 7 security domains. Options carry a raw score **s** of 1, 2, 3, or 4 — normalised later to a 0–100 domain percentage ($\text{pct} = \text{round}((\text{avg_s} - 1) / 3 * 100)$). The "Why this question" notes explain the threat model behind each one.

Q1 — Identity & Access · Remote access posture

Question: *How do your employees access internal and cloud applications remotely?*

Option	Score
VPN only	1
VPN + MFA	2
ZTNA for critical apps (Zscaler, Netskope, Prisma Access)	3
Full ZTNA, no VPN dependency	4

Why this question: Credential theft via phishing is the #1 initial-access vector in 2023–24 incident reports for India. A VPN gives an attacker who has stolen credentials access to the entire flat internal network. ZTNA scopes that blast radius to one app at a time. The gap between option 1 and option 4 is the difference between one stolen password = total compromise and one stolen password = one app exposed.

Glossary terms surfaced: ZTNA, VPN.

Q2 — Identity & Access · Privileged access management

Question: *How do you manage admin and privileged accounts?*

Option	Score
Shared credentials or static passwords	1
Individual accounts + basic AD/LDAP controls	2
Dedicated PAM tool (CyberArk, BeyondTrust, Delinea)	3
Just-in-time access + zero standing privilege	4

Why this question: Privileged account abuse is the most damaging breach pattern (lateral movement, ransomware deployment, data exfil). Shared creds destroy auditability. Standing admin rights give attackers persistent privilege; JIT access is the modern best practice. This question separates organisations where a stolen admin password ruins their year from those where it's contained in 15 minutes.

Glossary terms surfaced: PAM, AD / LDAP.

Q3 — Network Security · Firewall posture

Question: *What's your current firewall setup?*

Option	Score
No dedicated firewall, relying on ISP or router defaults	1
Legacy or basic stateful firewall (older Cisco ASA, basic appliances)	1
Next-gen firewall (Fortinet, Palo Alto, Check Point)	2
NGFW + active threat feeds + IDS/IPS tuned to your environment	3
NGFW + micro-segmentation + east-west traffic inspection	4

Why this question: The firewall is the perimeter. Legacy stateful firewalls only filter by port and IP; modern attacks use legitimate ports (443/80) and need application-layer inspection. Micro-segmentation prevents lateral movement once the perimeter is breached — without it, one compromised endpoint can reach the crown-jewel database. This question is especially heavy-weighted for Manufacturing (OT segmentation) and Government (perimeter-first models).

Glossary terms surfaced: NGFW, IDS / IPS, Micro-segmentation.

Q4 — Network Security · DDoS resilience

Question: *What happens if a volumetric DDoS attack hits your public-facing apps?*

Option	Score
We'd find out when customers complain	1
Basic ISP or firewall-level protection	2
Cloud-based scrubbing (Cloudflare, Akamai, AWS Shield)	3
Backbone-level inline scrubbing	4
I'm not sure what DDoS protection we have	1 (unsure)

Why this question: DDoS attacks are cheap to launch (■500 on dark-web stresser services) and increasingly used as cover for data exfiltration or extortion. Indian banking and eCommerce sites are routinely targeted during sale periods or regulatory deadlines. The score gap maps directly to "downtime cost in lost transactions" — option 1 is hours-of-outage exposure; option 4 is sub-minute mitigation.

Glossary terms surfaced: DDoS, Scrubbing.

Q5 — Detection & Response · Monitoring stack

Question: *What's your threat monitoring and detection setup?*

Option	Score
No centralised logging or SIEM	1
Basic SIEM with standard rules (Splunk, QRadar, ArcSight)	2
SIEM + SOAR with defined playbooks	3
Managed SOC with AI-assisted triage (24x7, MDR)	4
I'm not sure what monitoring tools we use	1 (unsure)

Why this question: Mean time to detect (MTTD) is the single most predictive metric of breach cost. Industry data shows the average breach goes undetected for 200+ days; with managed XDR/MDR that drops to under 48 hours. A SIEM alone without SOAR is high-noise low-signal; MDR is the leveraged answer for organisations that can't justify a 24x7 in-house team. This question is the most diagnostic for Detection & Response capability gaps.

Glossary terms surfaced: SIEM, SOAR, MDR.

Q6 — Detection & Response · 2am breach response

Question: *If a breach happened at 2am, how would the first 30 minutes go?*

Option	Score
Honestly, we'd probably find out hours later	1
Someone gets paged and starts investigating manually	2
SOC or MSSP triages within 15 minutes, runbook invoked	3
Managed SOC contains within 15 min, IR retainer auto-engaged	4

Why this question: This is the realism check. Many organisations have tooling but no operational maturity — the tools alert, but nobody acts in time. The 2am framing forces honesty: weekday 11am incidents are easy; the question is what happens at 2am on a Sunday. Answer reveals not just toolset but team readiness, runbooks, IR retainer presence, and escalation procedures. This is what regulators (RBI, CERT-In) actually audit.

Glossary terms surfaced: MSSP, IR retainer.

Q7 — Governance & Compliance · Regulatory tracking

Question: *How are you tracking compliance with Indian regulations? (DPDPA, RBI, SEBI, IRDAI, CERT-In 6-hour reporting)*

Option	Score
We rely on legal or audit to flag issues	1
Spreadsheet owned by one team, updated ad hoc	2
GRC tool with mapped controls, reviewed quarterly	3
Continuous compliance monitoring, auto-mapped controls, real-time dashboard	4
I'm not sure how we track regulatory compliance	1 (unsure)

Why this question: India's regulatory landscape has tightened dramatically since 2022 — DPDPA (2023), CERT-In's 6-hour breach notification mandate, RBI's master directions on IT/cyber, SEBI's CSCRF for stock-market entities. Non-compliance carries financial penalties (₹250 crore under DPDPA), reputational damage, and regulator-mandated disclosures. This question is weighted heaviest for BFSI and Government, where compliance failure has direct financial exposure.

Glossary terms surfaced: DPDPA, CERT-In 6hr, GRC.

Q8 — Governance & Compliance · Testing cadence

Question: *How often do you run security audits or VAPT?*

Option	Score
Never, or only after an incident	1
Annual audit, mostly compliance-driven	2
Bi-annual VAPT + periodic red team exercises	3
Continuous scanning + quarterly third-party audits + red team on retainer	4

Why this question: Vulnerabilities are introduced continuously (every code change, every cloud config update). Annual VAPT is months behind by definition; continuous scanning + red team retainer is the modern stance. RBI mandates annual VAPT for banks; for advanced organisations, the question is no longer "did you do it?" but "are you under continuous adversarial validation?". Triggers the Advisory engine's VAPT engagement in most industries.

Glossary terms surfaced: VAPT, Red team.

Q9 — Workforce Security · Endpoint posture

Question: *What's running on your endpoints, laptops, mobiles, workstations?*

Option	Score
No dedicated endpoint security, bare OS	1

Option	Score
Legacy AV only (Defender basic, McAfee, Symantec AV)	1
Next-gen AV with some behavioural detection	2
EDR deployed across most devices (CrowdStrike, SentinelOne, Defender for Endpoint)	3
Managed XDR, unified across endpoint, email, network, and cloud	4

Why this question: Endpoints are the primary breach origin (phishing → endpoint compromise → privilege escalation → lateral movement). Legacy signature-based AV catches <30% of modern malware. EDR records full process / network / file telemetry, allowing investigators to see what an attacker actually did. Managed XDR ties endpoint signals to email / cloud / network for cross-source detection — the difference between "we got hit" and "we got hit and we know exactly what happened".

Glossary terms surfaced: EDR, XDR.

Q10 — Workload Security · Data discovery and classification

Question: *Do you know where your sensitive data lives? (PII, financial records, source code, PCI data)*

Option	Score
Not really, it's sprawled across systems and SaaS tools	1
We've manually mapped 3–5 critical data stores	2
Data classification rolled out, DSPM/CSPM scans run regularly	3
Continuous discovery, classification, lineage, and auto-remediation across multi-cloud + SaaS	4
I'm not aware of where our sensitive data sits	1 (unsure)

Why this question: DPDPA's "Data Fiduciary" obligations require organisations to know what personal data they hold, where, who can access it, and how to respond to data principal rights requests. Without DSPM, this is impossible at any scale. Also feeds into breach-notification requirements: regulators ask "what data was at risk?" — if you can't answer in hours, you compound a security incident into a compliance incident. Weighted heaviest for Healthcare, IT/ITES, and Retail (PII-intensive industries).

Glossary terms surfaced: DSPM, CSPM, PII.

Q11 — Workload Security · Cloud workload protection

Question: *How are your cloud workloads protected? (VMs, containers, serverless, APIs)*

Option	Score
Cloud-native defaults only (AWS Security Hub, Azure Defender basic)	1
CSPM tool in place (Wiz, Orca, Prisma Cloud)	2
CSPM + CWPP + container and Kubernetes security	3
CNAPP, unified posture, workload protection, API security, and shift-left scanning	4
I'm not sure how our cloud workloads are secured	1 (unsure)

Why this question: The shared-responsibility model means cloud providers secure the infrastructure but customers secure the workloads — misconfigurations cause >70% of cloud breaches (S3 buckets, IAM roles, exposed Kubernetes APIs). Native cloud security tools are reactive; CNAPP is the modern integrated answer (shift-left scanning + runtime protection + posture + API security in one platform). Heaviest weight for IT/ITES and Healthcare where most workloads are cloud-native.

Glossary terms surfaced: CWPP, CNAPP, Kubernetes.

Q12 — AI Technology · GenAI risk posture

Question: *What's your posture on AI and GenAI tools being used in your org?*

Option	Score
Employees use whatever they want, no policy or controls	1
Public GenAI tools blocked at proxy, one sanctioned tool approved	2
Prompt filtering, DLP on AI traffic, usage logged and audited	3
Model integrity scanning, prompt-injection defence, AI-IAM, runtime monitoring	4

Why this question: GenAI is the fastest-growing new attack surface in enterprise security. Two risks: (1) shadow AI — employees pasting customer data, source code, or financials into ChatGPT-class tools, with no DLP on the egress; (2) AI in your product — model integrity, prompt injection, training data leakage. This is the only question with a 5% weight across all industries, because nobody has answered it well yet — but it's directional and lets us flag organisations that are years ahead vs. years behind.

Glossary terms surfaced: GenAI, DLP, Prompt injection.

Appendix D — Industry Weighting Rationale

Each industry weights the 7 domains differently because each industry has a different threat model and a different regulatory baseline. Below: the rationale for each industry's vector, why specific domains are weighted

up, and the corresponding regulatory and threat drivers.

Weight matrix at a glance

Domain	BFSI	Healthcare	Govt / PSU	Manufacturing	IT/ITES	Retail
Governance & Compliance	0.25	0.20	0.25	0.15	0.10	0.15
Identity & Access	0.20	0.15	0.15	0.10	0.20	0.20
Network Security	0.10	0.10	0.20	0.25	0.10	0.15
Detection & Response	0.15	0.15	0.20	0.20	0.15	0.15
Workforce Security	0.05	0.10	0.05	0.15	0.10	0.10
Workload Security	0.20	0.25	0.10	0.10	0.25	0.20
AI Technology	0.05	0.05	0.05	0.05	0.10	0.05
Total	1.00	1.00	1.00	1.00	1.00	1.00

Bold = highest-weighted domain(s) for that industry.

BFSI — Governance 0.25, Identity 0.20, Workload 0.20

Top drivers: - **Regulatory weight is the single biggest exposure.** RBI master directions on cyber security, RBI Digital Payment Security Controls, SEBI's CSCRF, IRDAI Information & Cyber Security guidelines, plus DPDPA and CERT-In's 6-hour reporting. Non-compliance carries direct financial penalty and regulator-mandated disclosure. → G&C **0.25**. - **Customer identity is the product.** UPI fraud, account takeover, mule networks. Every authentication weakness translates directly to financial loss. → IAM **0.20**. - **Sensitive data sprawl across core banking + cloud + partners.** PII + financial data + transaction logs need formal classification, lineage, and access controls. → Workload **0.20**.

Lower weights: - Network at 0.10 — branch-and-DC network architecture is mature in BFSI; the perimeter has been solved for years. The attack vector has moved to identity and cloud. - Workforce at 0.05 — BFSI typically has corporate-controlled endpoints and structured EDR; less variance than industries with BYOD or field workforces. - AI at 0.05 — emerging risk, not yet primary.

Healthcare — Workload 0.25, Governance 0.20

Top drivers: - **PHI is the highest-value data category on the dark web.** Medical records sell for 10–50× the price of credit card data. Hospital systems are also ransomware targets (life-critical pressure to pay). → Workload **0.25**. - **DPDPA Sensitive Personal Data + sector guidance from ABDM and CDSCO.** Healthcare-specific obligations on data residency, consent, audit. → G&C **0.20**.

Lower weights: - Network at 0.10 — most hospitals have manageable perimeters but Workload risk dominates.
- AI at 0.05 — clinical AI / diagnostics emerging but not yet mainstream.

Government / PSU — Governance 0.25, Network 0.20, Detection & Response 0.20

Top drivers: - **Highly regulated, NCIIPC-flagged critical infrastructure.** Strict GoI guidelines, CERT-In compliance, sector-specific MeitY norms. → G&C **0.25**. - **Nation-state targeting is the realistic threat model.** Indian government and PSU networks are constantly probed. Perimeter and detection layers are heavy because the adversary is sophisticated. → Network **0.20** + D&R **0.20**.

Lower weights: - Workload at 0.10 — many govt workloads remain on-premises or in sovereign clouds; less cloud-native than enterprise. - Workforce at 0.05 — controlled-environment workstations dominate.

Manufacturing / OT — Network 0.25, Detection & Response 0.20

Top drivers: - **OT and IT convergence.** Factory floor SCADA / PLC systems connected to IT networks, often legacy, often unpatched. The blast radius of a network compromise includes physical production halts. → Network **0.25**. - **OT attacks are rare but catastrophic.** Detection of lateral movement from IT into OT is the highest-leverage capability. Manufacturing customers in India have been ransomware-paralysed (production losses ■100 crore+). → D&R **0.20**.

Lower weights: - Governance at 0.15 — fewer industry-specific regs than BFSI / Healthcare. - Workload at 0.10 — most workloads are factory-floor, not cloud. - Identity at 0.10 — fewer end-users; operator accounts on OT systems are a different control problem.

IT / ITES / SaaS — Workload 0.25, Identity 0.20

Top drivers: - **Cloud-native by default.** AWS / Azure / GCP estates with hundreds of services, containers, serverless functions. The most common breach root cause is cloud misconfiguration. → Workload **0.25**. - **Identity is the new perimeter.** ZTNA, SSO, conditional access, privileged access on cloud consoles. SaaS organisations live or die on identity hygiene. → IAM **0.20**.

Lower weights: - Governance at 0.10 — fewer sector-specific regs (DPDPA still applies); the model is "we're audited by customers, not regulators". - AI at 0.10 — slightly elevated because IT/ITES firms ship AI features and consume LLMs heavily.

Retail / eCommerce — Identity 0.20, Workload 0.20

Top drivers: - **Customer account takeover is the primary fraud vector.** Bot-driven credential stuffing, payment fraud. → IAM **0.20**. - **Cloud + SaaS data sprawl.** Order data, payment tokens, loyalty PII, third-party logistics integrations. PCI-DSS for card data, DPDPA for PII. → Workload **0.20**. - **DDoS during sale events.** Real, ongoing risk during Diwali, Big Billion Day, Year-end sales. Network gets a moderately elevated 0.15. → Network **0.15**.

Lower weights: - Workforce at 0.10 — store-employee BYOD risk is real but lower than central data risk. - AI at 0.05 — recommendation and personalisation use AI but not the primary security frontier.

How the weights interact with the recommendation engine

The weakest weighted domain (lowest $\text{pct} \times \text{weight}$) is what the recommendation engine targets first. So a BFSI customer with low Governance & Compliance scores will see Professional Services and Managed Services surfaced before anything else. An IT/ITES customer with low Workload scores will see Secure Workload first. The weighting is what makes the recommendation industry-specific.

This is also why the same 0–100 maturity score can produce different stack recommendations across industries — the weakness profile differs.

How weights influence the architecture diagram

The maturity weights don't feed directly into the architecture engine, but they influence the **default Architecture tier** via the bridge logic (§9). An industry whose customers tend to score lower defaults to Starter; mature customers from heavily-regulated industries default to Standard; Advanced customers default to Advanced. The architecture engine itself reads **industry**, **environment**, **size**, derived **concerns**, derived **maturity**, and **industryRegs**.

End of documentation.